I. PURPOSE

This policy provides a structured set of principles for protecting privacy and serves as a roadmap for agencies to use in identifying and implementing privacy principles for the entire life cycle of Personal Information (PI), whether in paper or electronic form.

II. DEFINITIONS

A. "Agency" – means any department, program cabinet, institution, board, commission, office or agency of the state as defined in KRS 11.080 and as the term agency is used in KRS 11.090 to 11.110, with the exception of universities and colleges.

B. "Personal Information" (PI) – means, as defined in KRS 61.931(6), an individual's first name or first initial and last name; personal mark; or unique biometric or genetic print or image, in combination with one (1) or more of the following data elements:

a. An account number, credit card number, or debit card number that, in combination with any required security code, access code, or password, would permit access to an account;

b. A Social Security number;

c. A taxpayer identification number that incorporates a Social Security number;

d. A driver's license number, state identification card number, or other individual identification number issued by any agency;

e. A passport number or other identification number issued by the United States government; or

f. Individually identifiable health information as defined in 45 C.F.R. sec. 160.103, except for education records covered by the Family Educational Rights and Privacy Act, as amended, 20 U.S.C. sec. 1232g.

III. POLICY AND PROCEDURES

1. The following provides a structured set of privacy controls, based on National Institute of Standards and Technology (NIST) best practices, that are designed to assist agencies' compliance with applicable federal laws, Executive Orders, directives, instructions, regulations, policies, standards, guidance, and agency-specific issuances;

a) Authority and Purpose:

i) Authority to Collect: The agency must determine and document the legal authority that permits the collection, use, maintenance, and sharing of PI, either generally or in support of a specific program or information system need.

ii) Purpose Specification: The agency must describe the purpose(s) for which PI is collected, used, maintained, and shared in its privacy notices, and must ensure that these descriptions are clear, concise, and written in plain language that is accessible to the public.

The agency must tag or otherwise associate with the specific purpose(s) for which it was collected, maintained, and used. These purpose designations must be preserved and referenced during data lifecycle events and system access or disclosure decisions.

b) Accountability, Audit and Risk Management:

i) Governance and Privacy Program: The agency must:

(1) Appoint an agency privacy officer accountable for developing, implementing, and maintaining an agency-wide governance and privacy program to ensure compliance with all applicable laws and regulations regarding the collection, use, maintenance, sharing, and disposal of PI by programs and information systems;

(2) Monitor all applicable privacy laws (federal and state), and policy for changes that affect the privacy program;

(3) Allocate budget, staff, and other sufficient resources to implement and operate the agency-wide privacy program;

(4) Develop a strategic agency privacy plan for implementing applicable privacy controls, policies, and procedures;

(5) Develop, disseminate, and implement operational privacy policies and procedures that govern the appropriate privacy and security controls for programs, information systems, or technologies involving PI; and

(6) Update the privacy plan, policies, and procedures every two years.

ii) Privacy Impact and Risk Assessment: The agency must:

(1) Document and implement a privacy risk management process that assesses privacy risk to individuals resulting from the collection, sharing, storing, transmitting, use, and disposal of PI; and

(2) Conduct Privacy Impact Assessments (PIAs) for information systems, programs, or other activities that pose a privacy risk in accordance with applicable law, policy, or any existing agency policies and procedures.

iii) Privacy Requirements for Contractors and Service Providers: The agency must:

(1) Establish privacy roles, responsibilities, and access requirements for contractors and service providers; and

(2) Include applicable privacy requirements in contracts and other acquisition-related documents.

iv) Privacy Monitoring and Auditing: The agency must monitor and audit privacy controls and internal privacy policy every two years to ensure effective implementation.

v) Privacy Awareness and Training: The agency must:

(1) Develop, implement, and update a comprehensive training and awareness strategy aimed at ensuring that personnel understand privacy responsibilities and procedures.

(2) Administer basic privacy training at least annually and target role-based privacy training for personnel having responsibility for PI for activities that involve PI.

(3) Ensure that personnel certify (manually or electronically) acceptance of responsibilities for privacy requirements.

vi) Privacy Reporting: The agency develops, disseminates, and updates reports to the Commonwealth Office of Technology (COT), as appropriate, to demonstrate accountability with specific and regulatory privacy program mandates, to senior management, and other personnel with responsibility for monitoring privacy program progress and compliance.

vii) Privacy-Enhanced System Design and Development: The agency must design information systems to support privacy by automating privacy controls. Information systems should be designed to enforce processing of PI only for the authorized purposes explicitly stated in public notices or legal authority. System logic, workflows, and access controls shall reflect these constraints to prevent unauthorized use or disclosure.

viii) Accounting of Disclosures: The agency must:

(1) Keep an accurate accounting of disclosures of information held under its control, including:

(a) Date, nature, and purpose of each disclosure of a record; and

(b) Name and address of the person or agency to which disclosure was made.

(2) Retain the accounting of disclosures for the life of the record or five years after the disclosure is made, whichever is longer, for systems that require compliance with the Privacy Act of 1974; for Commonwealth systems, retain the accounting of disclosures for five years, or according to the agency's record retention policy, whichever is longer; and

(3) Makes the accounting of disclosures available to the person named in the record upon appropriate request.

c) Data Quality and Integrity:

i) Data Quality: The agency must:

(1) Confirm, to the greatest extent practicable, upon collection or creation of PI, the accuracy, relevance, timeliness, and completeness of that information;

(2) Collect PI directly from the individual to the greatest extent practicable;

(3) Check for, and correct as necessary, any inaccurate or outdated PI used by its agency systems; and

(4) Issue guidelines ensuring and maximizing the quality, utility, objectivity, and integrity of disseminated information.

ii) Data Integrity and Data Integrity Board: The agency must:

(1) Document processes to ensure the integrity of PI through existing security controls; and

(2) Establish a Data Integrity Board, when appropriate, and as needed, to comply with requirements for oversight of agency computer Matching Agreements, required for Federal systems, and to ensure that those agreements comply with the computer matching provisions of the federal Privacy Act of 1974.

d) Data Minimization and Retention:

i) Minimization of PI: The agency must:

(1) Identify the minimum PI elements that are relevant and necessary to accomplish the legally authorized purpose of collection;

(2) Limit the collection and retention of PI to the minimum elements identified for the purposes described in the notice and for which the individual has provided consent, if consent is required; and

(3) Conduct an initial evaluation of PI holdings, establish and follow a schedule for regular review of these holdings every two years or, if the agency must comply with the federal Privacy Act of 1974 requirements, annually, to ensure that only PI identified in the notice is collected and retained, and that the PI continues to be necessary to accomplish the legally authorized purpose.

ii) Data Retention and Disposal: The agency must:

(1) Retain each collection of PI for the time period required to fulfill the purpose(s) identified in the notice or as required by law;

(2) Dispose of, destroy, erase, anonymize the PI regardless of the method of storage, in accordance with the agency's record retention schedule and in a manner that prevents loss, theft, misuse, or unauthorized access; and

(3) Use agency defined security methodology to ensure secure deletion or destruction of PI including original copies and archived records.

iii) Minimization of PI used in Testing, Training, and Research: The agency must:

(1) Develop policies and procedures that minimize the use of PI for testing, training, and research; and

(2) Implement policies and procedures to protect PI used for testing, training, and research.

e) Individual Participation and Redress:

i) Consent: The agency must:

(1) Provide a means, where feasible and appropriate, or as required by statute or regulation, for individuals to authorize the collection, use, maintaining, and sharing of PI prior to its collection;

(2) Provide appropriate means for individuals to understand the consequences of the decision to approve or decline the authorization of the collection, use, dissemination, and retention of PI;

(3) Obtain consent, where feasible and appropriate, or as required by statute or regulation, from individuals prior to any new uses or disclosure of previously collected PI; and

(4) Ensure that individuals are aware of and, where feasible, or as required by statute or regulation, consent to all uses of PI not initially described in the public notice that was in effect at the time the agency collected the PI.

(5) Where feasible and appropriate the agency shall track the status of individual consent and associate that consent with the corresponding. Consent tracking records must reflect whether, when, and for what purpose consent was granted, revoked, or expired.

(6) Where feasible and appropriate, the agency shall offer individuals the ability to provide selective consent to specific uses or disclosures of their PI, rather than relying solely on broad or bundled consent mechanisms.

ii) Individual Access: The agency must:

(1) Individuals shall be provided with the ability to access records containing their PI that are maintained by the agency, in accordance with applicable laws and agency policy. System-level access controls shall enforce that individuals can only access records pertaining to their own PI through identity verification mechanisms, including multifactor authentication and unique user credentials. All access to such records shall be logged and monitored.;

(2) The agency shall establish and publish formal policies and procedures that govern how individuals may request access to records maintained in systems of records, as defined under the Privacy Act of 1974, or other agency-managed records containing PI. These procedures shall include responsible roles, approval workflows, and timelines, and shall be reviewed and updated on an annual basis or as needed to maintain compliance with legal and regulatory changes.;

(3) Access request procedures and privacy program information shall be published in locations readily accessible to individuals who provide PI to the agency. These include, but are not limited to, the agency's public-facing website and internal portals. All materials shall be written in plain language, reviewed annually for accuracy, and maintained to ensure clarity and accessibility; and

(4) The agency shall adhere to all applicable requirements of the Privacy Act of 1974, if the Act is applicable to the agency, and relevant agency policies and guidance, to ensure the appropriate and timely processing of individual access requests. This includes validating the identity of the requester, maintaining records of requests and disclosures, and implementing safeguards to prevent unauthorized access or disclosure of personal data.

iii) Redress: The agency must:

(1) Provide a process for individuals to have inaccurate PI maintained by the agency corrected or amended, as appropriate; and

(2) Establish a process for disseminating corrections or amendments of the PI to other authorized users of the PI, such as external information-sharing partners and, where feasible and appropriate, notify affected individuals that their information has been corrected or amended.

(3) Require individuals to use multifactor authentication to access their own PI, in accordance with PT-7(1) NIST 800-53rev5.

(4) The agency shall require individuals to authenticate using multifactor authentication or equivalent secure methods before submitting a request to amend or correct records containing their PI.

iv) Complaint Management: The agency must implement a process for receiving and responding to complaints, concerns, or questions for individuals about agency privacy practices.

f) Security:

i) Inventory of PI: The agency must:

(1) Establish, maintain, and update an inventory that contains a listing of all programs and information systems identified as collecting, using, maintaining, or sharing PI every two years; and

(2) Provide each update of the PI inventory to COT, the Office of the Chief Information Officer (CIO) to support the establishment of information privacy and security requirements for all new or modified information systems containing PI every two years.

ii) Privacy Incident Response: The agency must:

(1) Develop, and implement a Privacy Incident Response Plan; and

(2) Provide an organized and effective response to privacy incidents in accordance with the agency's Privacy Incident Response Plan.

g) Transparency (TR):

i) Privacy Notice: The agency must:

(1) Provide effective notice to the public and to individuals regarding: (i) its activities that impact privacy, including its collection, use, sharing, safeguarding, maintenance, and disposal of PI; (ii) authority for collecting PI; (iii) the choices, if any, individuals may have regarding how the agency uses PI and the consequences of exercising or not exercising those choices; and (iv) the ability to access and have PI amended or corrected if necessary;

(2) Describe, (i) the PI the agency collects and the purpose(s) for which it collects that information; (ii) how the agency uses PI internally; (iii) whether the agency shares PI with external entities, the categories of those entities, and the purposes of such sharing; (iv) whether individuals have the ability to consent to specific uses or sharing of PI and how to exercise any such consent; (v) how individuals may obtain access to PI; and (vi) how the PI will be protected;

(3) Revise its public notices to reflect changes in practice or policy that affect PI or changes in its activities that impact privacy, before, or as soon as practicable, after the change.

ii) Dissemination of Privacy Program Information: The agency must:

(1) Ensure that the public has access to information about its privacy activities and the public is able to communicate with the agency's Privacy Officer; and

(2) Ensure that its privacy practices are publicly available through agency websites or other publicly available means.

h) Use Limitation:

i) Internal Use: The agency must use PI internally only for the authorized purpose(s) identified in public notices, or for agencies subject to federal regulation, the Privacy Act.

ii) Information Sharing with Third Parties: The agency must:

(1) Share PI externally, only for the authorized purposes as described in the agency's privacy notice(s), or, if applicable, according to the Privacy Act, for a purpose that is compatible with those purposes, or for a purpose authorized by statute or regulation;

(2) Where appropriate, enter into Memoranda of Understanding, Memoranda of Agreement, Letters of Intent, Service Level Agreements, Computer Matching Agreements, or similar agreements, with third parties that specifically describe the PI covered and specifically enumerate the purposes for which the PI may be used; and

(3) Monitor, audit, and train its staff on the authorized sharing of PI with third parties and on the consequences of unauthorized use or sharing of PI; and evaluate any proposed new instances of sharing PI with third parties to assess whether the sharing is authorized and whether additional or new public notice is required.

III. CORRECTIVE OR DISCIPLINARY ACTION

Each agency shall ensure that all relevant staff within their organizational authority are aware of, and comply, with this policy. The agency is responsible for enforcement of this policy. Unauthorized neglectful actions regarding this policy may result in disciplinary action up to, and including, dismissal. COT may require additional service charges for remediation efforts due to non-compliance with this policy.

IV. APPLICABILITY

All executive branch agencies and non-executive branch agencies using COT-managed infrastructure or services shall adhere to this policy. This includes employees, contractors, consultants, temporaries, volunteers, and other workers within state government. Organizations may modify this policy to fulfill their responsibilities but must obtain approval through an exception request. Staff should refer to their internal policy, which may have additional information or clarification.

V. REFERENCES

KRS 11.080 Definition of agency
KRS 11.090 Audit, Study or Survey of State Agencies
KRS 11.100 Right to Information – Access to Records
KRS 11.110 Compensation – From What Fund Paid
KRS 61.931 Definitions for KRS 61.931 to 61.934
45 C.F.R. sec. 160.103
20 U.S.C. sec. 1232g - Family Educational Rights and Privacy Act
National Institute of Standards and Technology (NIST)
5 U.S.C. § 552a - Privacy Act of 1974
NIST 800-53 Rev. 5